Information Security and Data Protection Policy

Nunoli Soluções Digitais Ltda (Pólia One) · Brazil
Version 1.0 · Effective October 23, 2026 · Approved by Silvia Nunes de Oliveira, Managing Partner

1. Purpose and scope

This policy defines how Pólia protects the information it handles: company data, data of Pólia One users, and third-party data received through users, such as their customers and orders from sales channels (TikTok Shop, Shopee). It applies to every system, account and device used to operate Pólia, and to anyone who is granted access to them.

2. Roles

- **Security and Privacy Officer and Data Protection Officer (DPO):** Silvia Nunes de Oliveira, privacidade@usepolia.com.br. Approves this policy, grants and revokes access, coordinates incident response and answers data subjects and authorities.
- **Anyone with access** (staff or contractors, when applicable): follows this policy, signs a confidentiality agreement before first access and reports any suspected incident to the Officer.

3. Data classification

Level	Examples	Rule
Restricted	Sales channel access tokens, API keys, passwords, payment data	Only in a secret manager or encrypted; never in source code, logs, spreadsheets or chat
Confidential	Personal data of users and their customers, orders, users' financial records	Access limited to the account owner and server-side processes; encrypted in transit and at rest
Internal	Product documents, aggregated metrics	Access limited to people working at Pólia
Public	Website, blog, privacy policy	No restriction

4. Access control

- Least privilege: every person and process accesses only what is required.
- In the product, every table holding user data enforces row-level security: an account can only read and write its own data. The database service key is used only on the server, never in the browser.
- Administrative functions require an admin role, checked on every request.
- Multi-factor authentication is mandatory on all administrative accounts (cloud infrastructure, database, source code repository, payment provider, email and partner portals).
- Production access is currently limited to the Officer. New access is individual (no shared accounts), recorded, reviewed every 6 months and revoked on the day it is no longer needed.

5. Encryption and secrets

- All traffic uses TLS (HTTPS).
- The database (Supabase managed PostgreSQL) is encrypted at rest (AES-256).
- Sales channel access tokens are stored in Supabase Vault, encrypted and readable only by server-side code.

- Production secrets are kept only in platform secret managers (Cloudflare Workers and Supabase secrets), never in source code, repositories, logs or conversations.

6. Endpoint and daily security baseline

- Automatic screen lock; strong, unique passwords per service, stored in a password manager.
- Antivirus with real-time protection (Microsoft Defender) and automatic operating system updates.
- Clean desk: no secrets or customer data on paper or visible on shared screens.
- Customer data is not downloaded to devices unless necessary, and is deleted after use.

7. Network and infrastructure

- The application runs on Cloudflare Workers behind Cloudflare's network (DDoS protection, TLS).
- The database is not exposed directly: access goes through authenticated APIs with row-level security.
- Restricted CORS, rate limiting on login and expensive operations, and bot verification (Cloudflare Turnstile) on public forms.

8. Secure development

- Every release passes a security checklist before deployment: secrets, input validation, object-level authorization, field exposure and dependencies.
- Database queries are always parameterized; output is escaped against XSS.
- Database changes are made through versioned migrations; database security advisors are reviewed after every schema change.

9. Vulnerability management

- Dependency scanning for known vulnerabilities before each release.
- Full application security review at least once a year and after major changes (the latest, in July 2026, produced 14 findings, all fixed and verified in production).
- Remediation deadlines: critical within 7 days, high within 30 days, medium and low in the regular cycle.

10. Logging and monitoring

- Application errors are logged without sensitive data.
- Automated production alerts (payment webhook failures, error rate spikes, site downtime) reach the Officer in real time.

11. Incident response

1. **Detect:** automated alert, or report from a user, partner or provider.
2. **Contain:** revoke affected tokens and keys, block access, fix the cause.
3. **Assess:** which data, whose, how much and for how long.
4. **Notify:** affected sellers and the originating partner (for example, TikTok Shop) by email within 48 hours of confirmation; data subjects and the Brazilian data protection authority (ANPD) when there is relevant risk or harm, as required by the LGPD (art. 48).
5. **Record and improve:** what happened, root cause, actions taken and changes to prevent recurrence.

12. Personal data protection (LGPD)

- Pólia is the controller of its users' data. For data about users' customers and marketplace orders, Pólia is a **processor** and processes it only to provide the service the user subscribed to.
- **Minimization:** from marketplace orders, Pólia keeps only what is needed to record the sale, stock movement and fees. The buyer's full address is not stored.
- **Marketplace buyer data** is not used for marketing, is never sold, and is never used to contact buyers outside the originating platform.
- **Retention:** account data is kept while the account exists, and users can delete their account and data themselves inside the product, with immediate deletion; marketplace access tokens are deleted upon disconnection; other marketplace data is deleted within 30 days after disconnection or account closure; records required by law (tax and financial) are kept for up to 5 years.
- **Data subject requests** (access, correction, deletion, portability) are handled through privacidade@usepolia.com.br within 15 days, including requests forwarded by partners such as TikTok Shop.
- **Sub-processors:** Supabase (database, United States), Cloudflare (application), Stripe (payments), Resend (email), Google (Calendar, Analytics, Gemini). A new sub-processor is added only with a data processing agreement and an update to the privacy policy.
- **International transfer:** data is stored in the United States (Supabase, us-east-2), based on the safeguards of LGPD art. 33 (contractual clauses and providers' data processing agreements).

13. Review

This policy is reviewed once a year, and earlier whenever the law changes, a new sub-processor is added or an incident occurs. The public privacy policy (usepolia.com.br/privacidade) follows the same rules.

Version	Date	Change
1.0	October 23, 2026	First version

Approved by Silvia Nunes de Oliveira, Managing Partner and Data Protection Officer
Nunoli Soluções Digitais Ltda · privacidade@usepolia.com.br · October 23, 2026